

UNVEILING CYBER THREATS: PENETRATION TESTING AND SYSTEM SECURITY

PROBING CYBER THREATS THROUGH PENETRATION TESTING



TEAM:

- *CH V S DATTA SANDEEP*
- *ANJALI KUMARI*
- *SWEJAN*
- *RISHITH*

- In our interconnected digital world, technology brings benefits but also heightened risks.
- The rising frequency and complexity of cyber threats are major concerns for all – individuals, businesses, governments.
- Dependence on digital platforms amplifies these risks. Strong system security is paramount, as one breach can mean severe financial losses, data compromise, and reputation damage.
- Penetration testing is gaining so much traction that it is estimated that by 2025, it will be a \$4.5 billion industry .
- 45% of organizations in Canada carried out penetration tests to identify cyber risks and prevent cybercrimes.
- Organizations that resolve vulnerabilities in less than 30 days are 2.7 times less likely to suffer a breach.

WHAT IS PENTESTING ?

- Penetration testing, often referred to as "pentesting," is a meticulously orchestrated and systematic approach to evaluating the security posture of digital systems, networks, and applications.
- It is an intricate process that replicates real-world cyber attacks in a controlled environment to unveil vulnerabilities and potential weaknesses that could be exploited by malicious actors.
- **In-depth security assessment:** Penetration testing goes beyond surface-level scanning and delves deep into a system's architecture, simulating attacks to expose hidden flaws.
- **Ethical hacking:** It involves ethical hacking techniques, where authorized experts emulate the strategies and methods used by cybercriminals, but with the purpose of identifying vulnerabilities rather than exploiting them.
- **Comprehensive Evaluation:** Penetration testing encompasses a comprehensive evaluation of an organization's digital infrastructure, including networks, applications, databases, and even physical security aspects.

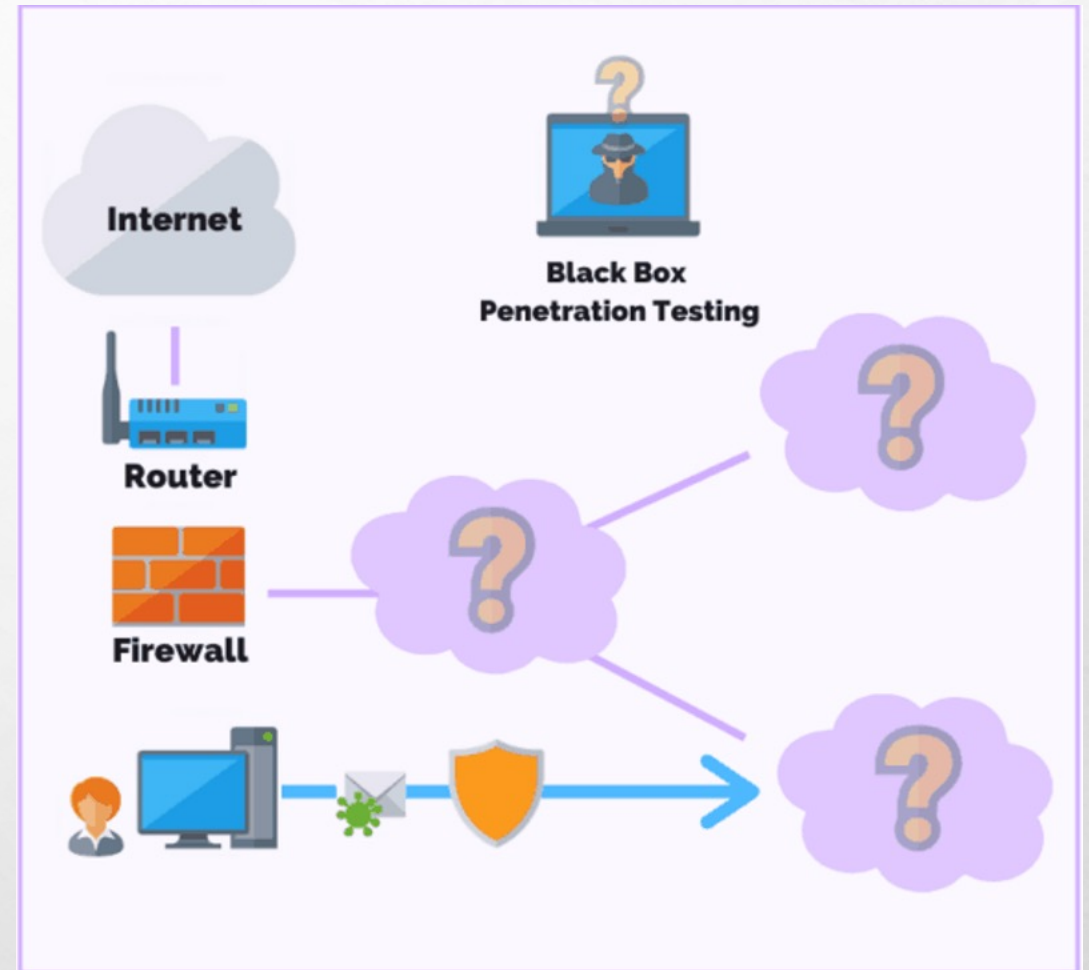
PURPOSE OF PENETRATION TESTING: IDENTIFYING VULNERABILITIES AND WEAKNESSES

- **Enhancing security resilience:** Penetration testing significantly enhances the overall security resilience of an organization. The insights gained from testing allow for a more strategic allocation of resources to fix critical vulnerabilities, thereby reducing the attack surface and strengthening defences.
- **Mitigating financial and reputational risks:** Effective penetration testing directly contributes to mitigating financial losses resulting from data breaches, litigation costs, and potential regulatory fines. It also safeguards an organization's reputation by demonstrating a proactive stance against cyber threats.
- **Strategic decision-making:** The insights derived from penetration testing empower decision-makers to allocate resources more effectively. Organizations can prioritize security measures based on the severity of identified vulnerabilities, leading to informed risk management strategies.

TYPES OF PENETRATION TESTING ENVIRONMENTS:

1.Black box testing: During a black box penetration test (also known as external penetration testing) the pen tester is given little to no information regarding the IT infrastructure of a target organization.

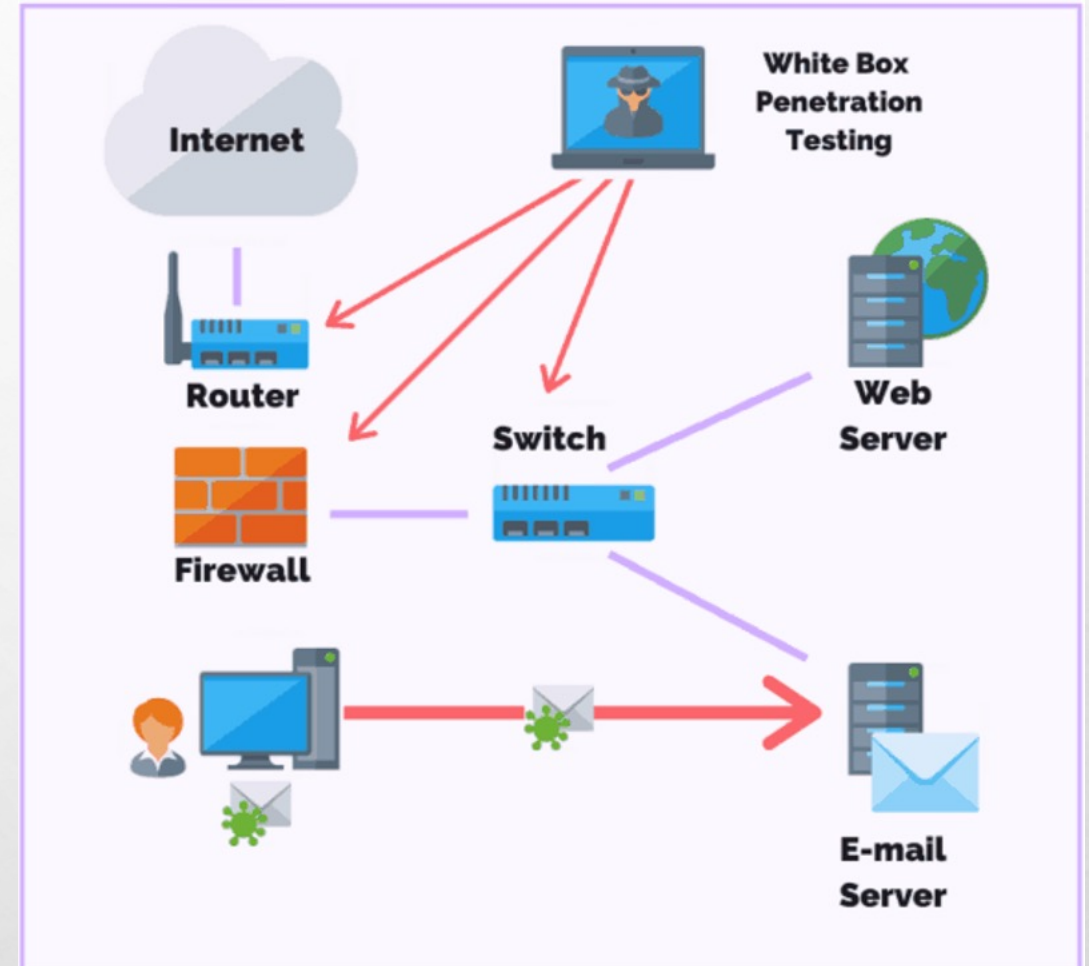
- The main benefit of this method of testing is to simulate a real-world cyber attack, whereby the pen tester assumes the role of an uninformed attacker.
- One of the easiest ways for pen testers to break into a system during a black box test is by deploying a series of exploits known to work, such as **Kerberoasting(trial and error approach)**



TYPES OF PENETRATION TESTING ENVIRONMENTS:

2.White box testing: White box penetration testing (also called clear box testing, glass box testing, or internal penetration testing) is when the pen tester has full knowledge and access to the source code and environment.

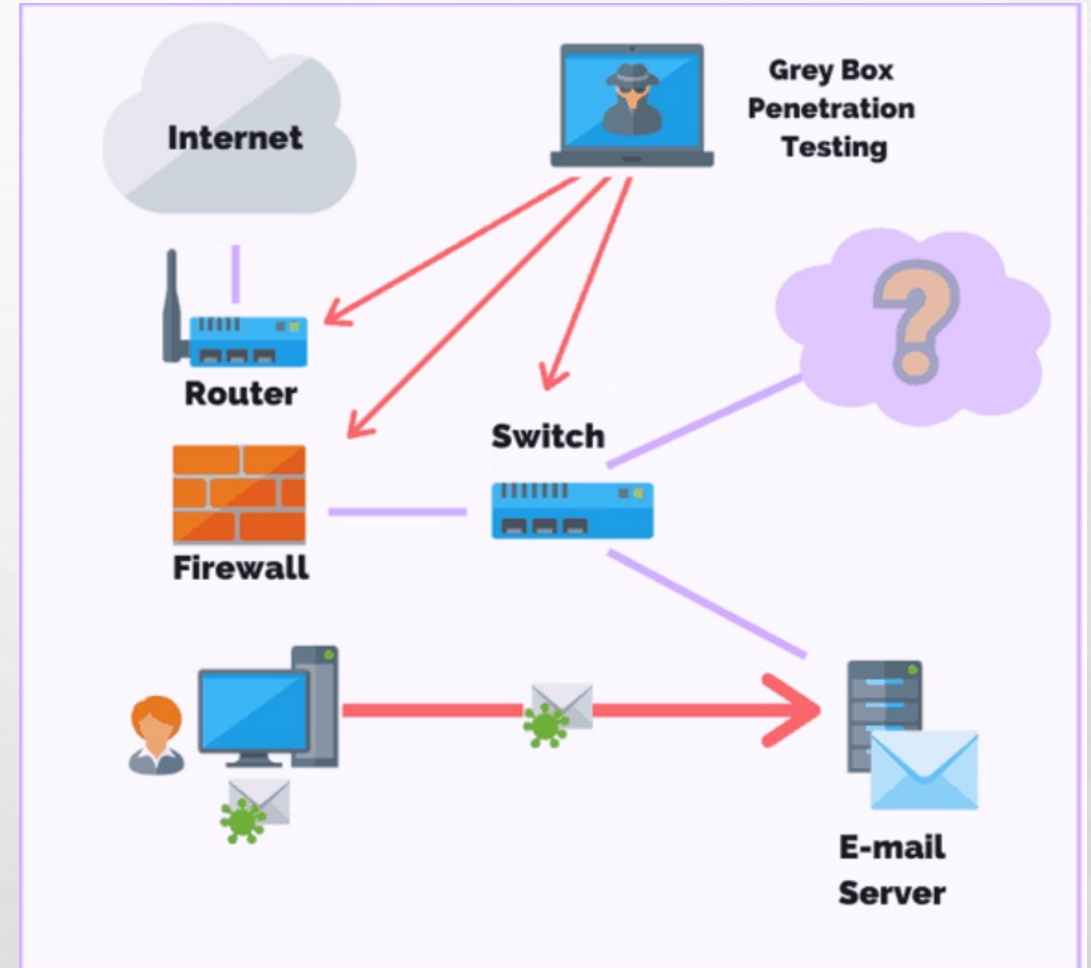
- The goal of a white box penetration test is to conduct an in-depth security audit of a business's systems and to provide the pen tester with as much detail as possible.
- White box tests do have their disadvantages. For instance, given the level of access the pen tester has it can take longer to decide what areas to focus on. In addition, this method of testing often requires sophisticated and expensive tools such as code analysers and debuggers.



TYPES OF PENETRATION TESTING ENVIRONMENTS:

3.Gray box testing: During a gray box penetration test, the pen tester has partial knowledge or access to an internal network or web application

- A pen tester may begin with user privileges on a host and be told to escalate their privileges to a domain admin. Or, they could be asked to get access to software code and system architecture diagrams.
- One main advantage of a gray box penetration test is that the reporting provides a more focused and efficient assessment of your network's security.



TOOLS USED FOR PENTESTING:

- N-Map (Network Mapper)
- Metasploit framework
- Burp suite
- Wireshark
- Nessus
- Aircrack-ng

Determining the scope of pentest

- Web app pentest
- End user and social engineering attacks
- Ddos and performance tests
- Network infrastructure tests
- External and internal network tests
- Mobile app pentest
- Virtualization system pentest
- Database pentest

PEN-TESTING STAGES:

Peneration Testing Stages

Planning and
Reconnaissance



Scanning



Gaining
Access



Maintaining
Access



Analysis



1. Planning and reconnaissance :

- The initial phase involves defining the scope of the penetration test, setting goals, and understanding the target system.
- Testers gather information about the target's infrastructure, network topology, and potential vulnerabilities.
- Reconnaissance helps identify potential entry points and attack vectors.
- **Passive reconnaissance:** in this preliminary phase, the penetration tester undertakes passive information gathering, relying on publicly accessible sources such as DNS records, databases, and social media platforms. This discrete approach allows the tester to glean valuable insights into the target organization's digital footprint without directly interacting with their systems.
- **Active reconnaissance:** transitioning to active reconnaissance, the tester employs techniques like network scanning and vulnerability scanning to discern more intricate details about the target's infrastructure. This step often involves identifying open ports, services running on these ports, and initial vulnerabilities that might be exploited in subsequent stages.

2. Scanning and enumeration

- The next step is to understand how the target application will respond to various intrusion attempts. This is typically done using:
 - **Static analysis** – Inspecting an application's code to estimate the way it behaves while running. These tools can scan the entirety of the code in a single pass.
 - **Dynamic analysis** – Inspecting an application's code in a running state. This is a more practical way of scanning, as it provides a real-time view into an application's performance.
- Enumeration dives deeper, gathering specific information about user accounts, system configurations, and other data that can be leveraged during the exploitation phase.

3. Gaining access (exploitation)

- This stage uses web application attacks, such as cross-site scripting, SQL injection and backdoors, to uncover a target's vulnerabilities. Testers then try and exploit these vulnerabilities, typically by escalating privileges, stealing data, intercepting traffic, etc., To understand the damage they can cause.

4. Maintaining access (post- exploitation)

- The goal of this stage is to see if the vulnerability can be used to achieve a persistent presence in the exploited system— long enough for a bad actor to gain in-depth access. The idea is to imitate advanced persistent threats, which often remain in a system for months in order to steal an organization's most sensitive data.

5. Analysis

- The results of the penetration test are then compiled into a report detailing:
 - Specific vulnerabilities that were exploited
 - Sensitive data that was accessed
 - The amount of time the pen tester was able to remain in the system undetected
 - This information is analysed by security personnel to help configure an enterprise's WAF settings and other application security solutions to patch vulnerabilities and protect against future attacks.

REAL WORLD SCENARIOS:

Example 1: The Equifax Data Breach

- The Equifax data breach in 2017 is one of the most significant data breaches in history. Equifax is one of the largest consumer credit reporting agencies in the United States. The breach exposed the personal information of 143 million individuals, including their names, social security numbers, birthdates, and addresses.
- Equifax hired a third-party vendor to conduct a penetration test on its systems. However, the vendor failed to identify a critical vulnerability in Equifax's web application framework, Apache Struts. This vulnerability allowed attackers to gain access to the company's sensitive data.
- If Equifax had conducted a thorough penetration test, this vulnerability would have been identified and remediated before the breach occurred. As a result, Equifax paid a hefty price, including paying out \$700 million in fines and settlements.

REAL WORLD SCENARIOS:

Example 4: The Canadian Government Cybersecurity Breach

- In 2019, the Canadian government experienced a cybersecurity breach that compromised the personal information of 9,041 individuals. The breach was caused by a vulnerability in the government's online portal for job seekers.
- The Canadian government hired a team of experts to conduct a penetration test on its systems. The test identified several vulnerabilities that could have been exploited by attackers to gain access to the government's sensitive data.
- The penetration test allowed the Canadian government to identify and address these vulnerabilities before any further attacks could occur. It also helped the government improve its cybersecurity posture and prepare for any future attacks.

FUTURE TRENDS IN PENETRATION TESTING:

- **Cloud security assessment:** As businesses migrate to cloud environments, penetration testing will increasingly focus on assessing the security of cloud infrastructure, ensuring data integrity, access controls, and compliance.
- **Iot device testing:** With the proliferation of internet of things (iot) devices, penetration testing will evolve to assess the security of these interconnected devices, identifying potential entry points for attackers.
- **Ai/ml integration:** The integration of artificial intelligence (AI) and machine learning (ML) in penetration testing tools will enhance the speed and accuracy of vulnerability detection, allowing for more efficient security assessments.

FUTURE TRENDS IN PENETRATION TESTING:

- **Zero trust architecture testing:** Zero trust is a strategic approach to cybersecurity that secures an organization by eliminating implicit trust and continuously validating every stage of a digital interaction. Rooted in the principle of “never trust, always verify,”
 - As the zero trust model gains traction, penetration testing will adapt to assess the security of perimeters, emphasizing the verification of all users and devices trying to access resources.
- **Red team operations:** A **red team** is a group that pretends to be an enemy, attempts a physical or digital intrusion against an organization at the direction of that organization, then reports back so that the organization can improve their defences.
- Organizations will increasingly adopt red team operations, where internal or external teams simulate real-world attacks. This approach provides a comprehensive evaluation of an organization's defence mechanisms.

System security and penetration testing: A symbiotic relationship

- **Comprehensive evaluation:** Penetration testing offers a thorough assessment, uncovering vulnerabilities that routine checks might miss.
- **Revealing weaknesses:** It exposes blind spots and potential targets that malicious actors could exploit.
- **Strengthening measures:** By identifying vulnerabilities, penetration testing guides proactive security reinforcement.
- **Realistic testing:** Simulating real-world attacks, it provides an adversarial perspective for accurate system defence evaluation.
- **Preventing breaches:** Insights from testing enable proactive vulnerability mitigation, reducing the risk of breaches.
- **Continuous enhancement:** Regular testing adapts security measures to evolving threats, ensuring ongoing system readiness.